

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Tool-Scope Audit Template

Audit whether each agent's tool permissions still match what it actually needs. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

TOOL-SCOPE AUDIT TEMPLATE

Version 1.3 Effective Date: [EFFECTIVE DATE] Prepared by: [AUDITOR NAME] Reviewed by: [STEWARD NAME] Last Updated: [LAST UPDATE DATE]

1. INTRODUCTION

This **Tool-Scope Audit Template** is designed for buyers governing AI agents in production environments. It ensures alignment with organizational risk tolerance, compliance requirements, and operational safeguards. This document is not a substitute for legal counsel but provides a structured framework for evaluating AI agent deployments across technical, governance, and financial dimensions.

Scope: - Applies to all AI agents deployed in [ORGANIZATION NAME]'s production systems, including but not limited to: - [LIST OF AI TOOLS/AGENTS] (e.g., LLM-based assistants, automation bots, decision-support systems) - [SPECIFIC USE CASES] (e.g., customer support, internal workflows, data analysis)

Exclusions: - [LIST OF EXCLUDED SYSTEMS] (e.g., sandbox environments, non-production prototypes)

Definitions: - **AI Agent:** An autonomous or semi-autonomous system that performs tasks using machine learning, NLP, or other AI techniques. - **Tool-Scope:** The defined boundaries of an AI agent's functionality, permissions, and data access. - **Governance Gate:** A predefined approval threshold for agent behavior, cost, or data handling.

2. AGENT IDENTIFICATION & SCOPE DEFINITION

2.1 Basic Metadata | Field | Value |

-----| | **Agent Name** | [AGENT NAME] | | **Owner/Requester** | [OWNER NAME] (e.g., [TEAM NAME]'s [ROLE TITLE]) | | **Requester's Manager** | [MANAGER NAME] | | **Deployment Environment** | [ENVIRONMENT] (e.g., Production, Staging, Multi-Cloud) | | **Primary Function** | [PRIMARY FUNCTION] (e.g., "Automate invoice validation") | | **Data Sources Accessed** | [LIST OF DATA SOURCES] (e.g., CRM, ERP, internal knowledge bases) | | **Third-Party Integrations** | [LIST OF INTEGRATIONS] (e.g., Slack, Salesforce, payment gateways) | | **AI Model Provider** | [PROVIDER NAME] (e.g., OpenAI, Mistral AI, custom in-house) | | **Model Version/Endpoint** | [MODEL VERSION] (e.g., gpt-4-1106-preview, [ORGANIZATION]'s custom LLM) |

2.2 Tool-Scope Boundaries | Category | Details |

-----| | **Functional Limits** | [DESCRIBE RESTRICTIONS] (e.g., "Cannot modify customer contracts without human approval") | | **Permissioning Rules** | [LIST OF ROLES/PERMISSIONS] (e.g., "Only [ROLE TITLE] can trigger agent in [ENVIRONMENT]") | | **Data Retention Policy** | [RETENTION RULES] (e.g., "All agent-generated outputs stored for [TIMEFRAME]") | | **Audit Trail Requirements** | [AUDIT LOG SPECIFICATIONS] (e.g., "Timestamp, requester, action, model response") |

2.3 Compliance & Policy Alignment | Regulatory Standard | Applicable? (Y/N) |

Evidence/Document | -----| | **GDPR** (if applicable) | [GDPR_APPLICABLE] | [DOCUMENT REFERENCE] | | **HIPAA** (if applicable) | [HIPAA_APPLICABLE] | [DOCUMENT REFERENCE] | | **CCPA** | [CCPA_APPLICABLE] | [DOCUMENT REFERENCE] | | **Internal Governance Policy** | [POLICY_NAME] | [POLICY DOCUMENT LINK] |

3. GOVERNANCE & CONTROL MECHANISMS

3.1 Approval Gates | Gate | Threshold | Approver |

-----| | **Cost Limit** |

[\$[MAX_COST_PER_INVOCATION]] or [\$[DAILY_BUDGET]] | [FINANCE_APPROVER_NAME] | |
Data Sensitivity | [SENSITIVITY_LEVEL] (e.g., PII, PHI) | [DATA_OWNER_NAME] | | **Behavioral**
Risk | [RISK_SCORE_THRESHOLD] (e.g., >2.5) | [SECURITY_STEWARD_NAME] | | **Third-Party**
Access | [INTEGRATION_APPROVAL_REQUIRED] | [IT_SECURITY_NAME] |

3.2 Permissioning Framework | Permission Type | Implementation Method | Owner |
 |-----|-----|-----|-----| | **Role-Based**
Access | [RBAC_TOOL] (e.g., IAM, Okta) | [IDENTITY_MANAGEMENT_NAME] | | **Temporary**
Elevation | [PROCEDURE_FOR_ESCALATION] | [OPERATIONS_TEAM_NAME] | | **Audit-Only Mode**
 | [AUDIT_ONLY_SWITCH_ENABLED] | [AUDIT_LOG_MANAGER_NAME] |

3.3 Cost Controls | Metric | Alert Threshold | Escalation Protocol |
 |-----|-----|-----|-----| | **Daily Spend |**
 [\$[DAILY_SPEND_ALERT]] | [FINANCE_ALERT_EMAIL] | | **Per-Request Cost |**
 [\$[PER_REQUEST_ALERT]] | [OPERATIONS_ALERT_EMAIL] | | **Anomaly Detection |**
 [ANOMALY_DETECTION_TOOL] (e.g., "3x baseline") | [COST_MONITOR_NAME] |

4. INCIDENT RESPONSE & RISK MITIGATION

4.1 Incident Classification | Severity Level | Definition | Response Team |
 |-----|-----|-----|-----| | **Critical (S1) |**
 [DESCRIBE CRITICAL] (e.g., "Data breach") | [INCIDENT_RESPONSE_TEAM_NAME] | | **High (S2) |**
 [DESCRIBE HIGH] (e.g., "Cost overrun") | [FINANCE_AND_SECURITY_NAME] | | **Medium (S3) |**
 [DESCRIBE MEDIUM] (e.g., "False positive") | [OPERATIONS_NAME] | | **Low (S4) |** [DESCRIBE
 LOW] (e.g., "Non-critical delay") | [AGENT_OWNER_NAME] |

4.2 Playbook Excerpts - For Cost Anomalies: - [STEP 1:](#) [ACTION] (e.g., "Pause agent and notify
 [FINANCE_ALERT_EMAIL]") - [STEP 2:](#) [ACTION] (e.g., "Review last 24-hour requests via
 [AUDIT_TOOL]") - [STEP 3:](#) [ACTION] (e.g., "Adjust budget in [FINANCE_SYSTEM]")

- For Data Exposure:
-

4.3 Risk Register | Risk | Likelihood | Impact | Mitigation | Owner |
 |-----|-----|-----|-----|-----|-----| |
 [RISK_1] | [1-5] | [1-5] | [MITIGATION_ACTION] | [OWNER_NAME] | | [RISK_2] | [1-5] | [1-5] |
 [MITIGATION_ACTION] | [OWNER_NAME] |

5. AUDIT TRAIL & TRANSPARENCY

5.1 Logged Events | Event Type | Fields Captured | Retention Period |
 |-----|-----|-----|-----| | **Invocation Logs |**
 [TIMESTAMP, REQUESTER, MODEL_RESPONSE, COST] | [RETENTION_DAYS] days | |
Permission Changes | [USER, ACTION, TIMESTAMP] | [RETENTION_DAYS] days | | **Cost**
Anomalies | [DATE, AMOUNT, REQUESTOR] | [RETENTION_DAYS] days |

5.2 Access Controls for Audit Logs | Role | View Permissions | Export Permissions |
 |-----|-----|-----|-----| | [ROLE_1] | [Y/N] |
 [Y/N] | | [ROLE_2] | [Y/N] | [Y/N] |

5.3 Third-Party Transparency (if applicable) - Vendor Audit Rights: [VENDOR_NAME] has access
 to [LIST OF LOG FIELDS] under [LEGAL BASIS]. - **Customer Audit Rights:**
 [ORGANIZATION_NAME] retains full audit logs for [TIMEFRAME].

6. ADOPTION NOTES & DOCUMENTATION

6.1 Buyer-Configurable Fields Verification This template includes [TOTAL_BRACKETED_FIELDS]
 buyer-fillable fields, all formatted as [BRACKETED_CAPS]. Each field is documented in the **Adoption**

Notes section below.

6.2 Adoption Notes	Field	Purpose	Example Value
	[EFFECTIVE_DATE]	Sets the validity period for this audit.	"2024-05-01"
	[AUDITOR_NAME]	Identifies the auditor responsible for this review.	"Jane Doe, Compliance Lead"
	[STEWARD_NAME]	Confirms oversight by the governance steward.	"Alex Chen, AI Governance Team"
	[AGENT_NAME]	Uniquely identifies the AI agent under review.	"InvoiceAutomator-v2"
	[OWNER_NAME]	Assigns accountability for the	

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com